

CAPÍTULO 7 · RESUMO DE ESTUDO

Auditoria em Sistemas de Informação e Banco de Dados

Os objetivos e o ciclo de auditoria em TI, as metodologias ISO 19011 e Itaf, as ferramentas de verificação e monitoramento, a auditoria de banco de dados como especialização, e os frameworks de governança (Cobit, Nist) que integram tudo isso — condensado para revisão antes da prova.

Curso Educação a Distância · Segurança e Auditoria de Sistemas de Informação

Base ABNT NBR ISO 19011:2018, Isaca (Cobit 2019, Itaf 4ª ed.), IIA, Intosai, Oracle, AWS, Nist CSF

1. Objetivos & ciclo

2. ISO 19011 & Itaf

3. Ferramentas

4. Auditoria de BD

5. Frameworks & integração

Termos-chave

Revisão rápida

01

Objetivos, tipos e ciclo de auditoria em TI

Auditoria em TI é uma análise metódica, independente e fundamentada em evidências, para verificar se sistemas, serviços e dados estão seguros, íntegros e apoiam os objetivos da empresa.

Os 5 eixos de objetivos

01

Conformidade

Aderência a leis, regulamentos, contratos, normas técnicas e políticas internas.

02

Segurança da informação

Confidencialidade, integridade, disponibilidade, autenticidade, não repúdio e rastreabilidade.

03

Integridade e qualidade de dados

Informações completas, precisas e atualizadas.

04

Eficiência e eficácia

Uso econômico dos recursos e contribuição dos serviços aos objetivos estratégicos.

05

Governança e riscos

Apoia a alta administração na identificação e priorização de riscos tecnológicos.

INTERNA X EXTERNA

Auditoria interna — realizada pela própria unidade de auditoria da empresa, para aprimorar controles internos. **Auditoria externa/independente** — conduzida por órgãos de controle ou empresas terceiras, gerando confiança para alta gestão, acionistas e sociedade. Outras abordagens: conformidade, operacional/desempenho, de sistemas/aplicações, de segurança da informação e especializadas (banco de dados, redes, desenvolvimento).

O ciclo de auditoria — 4 macrofases

fase 1

Planejamento

Objetivos, escopo, critérios, recursos, cronograma; avaliação preliminar de riscos e materialidade; decisão sobre uso de CAATs.

fase 2

Execução

Trabalho de campo: testes, entrevistas, observações, análise de documentos; controles gerais + de aplicação + testes substantivos.

fase 3

Relatório

Consolida achados e evidências; formula conclusões e recomendações com clareza, objetividade e completude.

fase 4

Follow-up

Verifica se as recomendações foram aplicadas, se as medidas corretivas foram eficazes, e atualiza o planejamento futuro.

02

Metodologias de auditoria: ISO 19011 e Itaf

Duas referências que se complementam: uma dá o macroprocesso, a outra especializa esse processo para TI.

Referência	Papel
ISO 19011	Diretrizes gerais para auditoria de sistemas de gestão (não específica de TI). Princípios: integridade, apresentação justa, devido cuidado profissional, confidencialidade, independência e abordagem baseada em evidências e riscos. Estrutura a gestão do programa de auditoria, o planejamento, a realização, o relatório e o follow-up.
Itaf (Isaca)	Padrões profissionais, diretrizes e procedimentos específicos para auditoria de TI, na 4ª edição — guia de referência para auditores certificados (ex.: Cisa). Cobre governança de TI, continuidade de negócios, internet banking, e reforça o uso de CAATs.

CAATS NÃO SÃO OBRIGATÓRIAS

As técnicas de auditoria assistidas por computador (CAATs) são amplamente recomendadas — especialmente para grandes volumes de dados — mas **não são uma exigência obrigatória** para todas as avaliações. O auditor deve justificar a estratégia escolhida considerando os riscos e as características do ambiente.

A ISO 19011 oferece o macroprocesso para auditoria de sistemas de gestão; o Itaf aplica esses princípios na prática de TI, tratando de governança, controles gerais e de aplicação, segurança, serviços terceirizados e ambientes complexos. As metodologias de auditoria em TI podem, assim, ser vistas como uma **especialização** da auditoria de sistemas de gestão.

03

Ferramentas de verificação e monitoramento

A análise de dados amplia a cobertura de testes, permite examinar 100% de certas populações (não só amostras) e produz evidências mais robustas — especialmente em auditorias internas.

Ferramenta	O que faz
Logs & Siem	Reúnem dados de várias origens e correlacionam eventos para reconhecer acessos suspeitos, falhas de autenticação e violações de política.
Scanners de vulnerabilidade	Verificam conformidade com configurações seguras e identificam vulnerabilidades conhecidas.
Comparação de configuração	Identifica desvios em relação às linhas de base (baselines) homologadas.
Plataformas de análise de dados	Criam scripts e modelos para detectar padrões de fraude, erros ou ineficiências em grandes volumes de transações.
Oracle AVDF	Audit Vault and Database Firewall — integra coleta e centralização de logs de auditoria com firewall que analisa e bloqueia comandos SQL não autorizados.
SQL Server audit / Extended Events	Mecanismos nativos de trilha de auditoria usados em implementações na nuvem (ex.: AWS RDS/EC2).

O PAPEL DO AUDITOR

Essas ferramentas costumam ser feitas para gestão do dia a dia ou segurança, não especificamente para auditoria. O auditor não deve se tornar um operador do sistema — deve aproveitar, de forma **independente**, logs, painéis e relatórios já existentes como fontes de evidência, elaborando consultas específicas quando necessário. O julgamento profissional continua central.

Os SGBDs concentram dados sensíveis (pessoais, financeiros) e são alvos prioritários. Principais riscos: acessos não autorizados, privilégios excessivos, trilhas de auditoria ausentes ou frágeis, políticas de backup inadequadas, falhas na segregação de funções e configurações inseguras.

Controle	O que garante
Gestão de usuários	Contas nomeadas (não genéricas), políticas de senha e autenticação forte, integração a diretórios corporativos.
Gestão de privilégios	Princípio do menor privilégio, aplicado por perfis e roles definidos.
Segregação de funções	Evita que uma mesma pessoa concentre administração de BD, desenvolvimento e auditoria.
Logs e trilhas de auditoria	Registram eventos críticos (logins com falha, alterações de privilégios, comandos DDL, backup/restore) em repositório protegido, idealmente separado do SGBD.
Backup, recuperação e hardening	Políticas alinhadas a RPO/RTO, testes periódicos de restauração, desativação de contas padrão, patches e criptografia em repouso/trânsito.

TRIGGERS E CDC NÃO SÃO O MECANISMO PRINCIPAL

Triggers de auditoria são fáceis de desativar/contornar sem controles compensatórios; o Change Data Capture (CDC) foi concebido para rastreamento de mudanças e replicação, não para segurança. As boas práticas recomendam priorizar os **mecanismos nativos de auditoria dos SGBDs**, integrados a soluções corporativas de logs e SIEM — deixando triggers e CDC como complementos pontuais e documentados.

Ciclo metodológico da auditoria de banco de dados

- 1 Entendimento do ambiente** — identifica SGBDs em uso, versões, instâncias e integrações com sistemas de negócio.
- 2 Avaliação de riscos e escopo** — prioriza bancos que armazenam dados sensíveis ou de alto impacto.

- 3 Revisão de usuários e privilégios** — extrai listas de logins, analisa contas administrativas e inativas.
- 4 Análise de parâmetros de segurança** — verifica se a auditoria está habilitada, quais eventos são registrados e por quanto tempo.
- 5 Revisão de logs e trilhas** — identifica padrões anômalos, logins com falha e acessos fora de horário.
- 6 Avaliação de backup e recuperação** — testes de restauração em ambiente de homologação.
- 7 Comparação com políticas e frameworks** — formula recomendações alinhadas ao apetite de risco da organização.

05

Frameworks de auditoria e integração com TI e banco de dados

A prática de auditoria em TI é fortemente influenciada por frameworks de governança, auditoria e segurança que se complementam em diferentes níveis.

Framework	Contribuição para a auditoria
Cobit 2019	Estrutura de governança e gestão de TI da Isaca. Objetivos relevantes: APO (align, plan, organize), DSS (deliver, service, support) e MEA (monitor, evaluate, assess) — ajudam a priorizar processos críticos.
Itaf	Padrões de auditoria de TI da Isaca, alinhados ao Cobit; complementado pelo documento "IS Standards, Guidelines and Procedures".
ISO/IEC 27001	Usada como critério de auditoria quando a organização é certificada ou busca conformidade com o padrão de SGSI.

Framework	Contribuição para a auditoria
Nist CSF / SP 800	Funções identify, protect, detect, respond, recover, govern — base para auditorias de segurança, gestão de identidades e resposta a incidentes.

TRÊS NÍVEIS DE INTEGRAÇÃO

Estratégico — Cobit e Nist CSF definem quais processos de TI são mais críticos. **Tático** — ISO 19011 e Itaf orientam a gestão do programa de auditoria e a definição de critérios. **Operacional** — guias do IIA, da Isaca e de fornecedores (Oracle, AWS) orientam o desenho de testes e a interpretação de resultados.

Benefícios do uso sistemático desses frameworks: consistência e comparabilidade entre auditorias, alinhamento a reguladores, credibilidade dos relatórios e capacitação de auditores (ex.: certificação Cisa). Desafios: adaptar frameworks globais à realidade local, evitar um uso meramente formalista (limitado a checklists) e manter atualização constante.



Termos-chave

Vocabulário que costuma aparecer em questões de múltipla escolha.

CAATs

Computer assisted audit techniques — técnicas de auditoria assistidas por computador.

Trilha de auditoria

Registro estruturado e rastreável das ações realizadas sobre um sistema/banco (quem, o quê, quando, de onde).

RPO / RTO

Objetivos de ponto de recuperação e de tempo de recuperação, que orientam a política de backup.

Materialidade

Relevância de um item ou desvio para as conclusões da auditoria.

DDL

Data definition language — comandos como create/alter/drop/truncate, monitorados por trilhas críticas.

Hardening

Reforço de segurança: desativação de contas padrão e serviços desnecessários, aplicação de patches.

Segregação de funções

Separação de responsabilidades para reduzir o risco de alteração ou eliminação de evidências.

Cisa

Certified Information Systems Auditor — credencial global de auditoria de sistemas de informação (Isaca).

Follow-up

Fase final do ciclo de auditoria: verifica se as recomendações foram implementadas e foram eficazes.

CDC

Change data capture — mecanismo de rastreamento de mudanças/replicação, não concebido para auditoria de segurança.



Revisão rápida antes da prova

Confira se você consegue responder a cada ponto sem consultar o texto.

- ☐ Listar os 5 eixos de objetivos da auditoria em TI (conformidade, segurança, integridade/qualidade, eficiência, governança/riscos).
- ☐ Diferenciar auditoria interna de auditoria externa/independente.
- ☐ Descrever as 4 macrofases do ciclo de auditoria: planejamento, execução, relatório, follow-up.
- ☐ Explicar a relação entre a ISO 19011 (macroprocesso) e o Itaf (aplicação específica para TI).
- ☐ Explicar por que as CAATs não são obrigatórias em toda auditoria de TI.
- ☐ Explicar por que o auditor não deve se tornar "operador do sistema" ao usar ferramentas de monitoramento.
- ☐ Listar os principais riscos associados a bancos de dados (acesso não autorizado, privilégios excessivos, trilhas frágeis etc.).

- ☐ Explicar por que triggers e CDC não são o mecanismo principal de auditoria de banco de dados.
- ☐ Descrever as 7 etapas do ciclo metodológico de auditoria de banco de dados.
- ☐ Explicar os 3 níveis de integração dos frameworks de auditoria (estratégico, tático, operacional) e um exemplo de cada.



Referências do capítulo

ABNT. NBR ISO 19011:2018 — Diretrizes para auditoria de sistemas de gestão.

AWS. Auditoria de instâncias, objetos de banco de dados e logins do SQL Server no Amazon RDS e no Amazon EC2, 2025.

IIBF — Indian Institute of Banking & Finance. Introduction on IS audit; audit in computerized environment.

Isaca. IS Standards, Guidelines and Procedures for Auditing and Control Professionals, 2009; Cobit 2019 Framework, 2018; IT Audit Framework (Itaf), 4. ed., 2020.

IIA — Institute of Internal Auditors. Global Technology Audit Guide (GTAG) 16: tecnologias de análise de dados, 2011.

Intosai. Guidance on audit of information systems (Guid 5100), 2019.

Nist. Framework for Improving Critical Infrastructure Cybersecurity v1.1, 2018; Cybersecurity Framework (CSF) 2.0, 2024.

Oracle Corporation. Oracle Audit Vault and Database Firewall — technical white paper, 2017; database activity monitoring and security posture management, 2025.

Resumo gerado a partir do capítulo "Auditoria em sistemas de informação e banco de dados" (SEG_AUD_SIS_07_ACE_2025) para revisão de prova.